WRITE-UP CTF — KATEGORI CRYPTOGRAPHY

Soal “hello”

Disusun oleh Tim “izin nyari flag bang” :

Andika Jusuf Jeremy Mustari (lieosyn)

1. Identifikasi

Diawali dengan membaca dan memahami alur dan fungsi dari source code yang diberikan. Kemudian kita menemukan beberapa hal yang harus dicari tahu, yaitu :

• Bagaimana public key (e) dan private key (d) saling berhubungan.

• Bagaimana pesan tersebut diubah menjadi angka, lalu dikunci.

• Keberadaan “celah” dari cara pada soal ini menyusun angka-angka.

Setelah pembacaan kode sumber, ditemukan hubungan yang tidak biasa. Pada RSA standar, kunci public dan kunci privat berhubungan melalui rumus e x d ≈ 1. Pada soal kali ini hubungannya sedikit berbelok menjadi e x d ≈ -1. Perbedaan ini mungkin kecil, namun ini yang merupakan pintu masuk untuk membongkar soal. e x d ≈ -1 merupakan varian serangan generalized Wiener Attack, dimana ini memanfaatkan hubungan matematis antara e dan d untuk menebak kembali private key dengan teknik yang sama namun variasi persamaan berbeda.

2. Asumsi

Berdasarkan identifikasi di atas, dibuatlah beberapa asumsi pengerjaan sebagai peta jalan penyelesaian:

A. Asumsi 1 = Private key (d) kemungkinan besar bisa ditebak dengan menebak pendekatan pecahan berjenjang. Teknik ini mencari pecahan sederhana yang nilainya sangat mendekati suatu angka besar
B. Asumsi 2 = Begitu private key didapat, dua bilangan prima rahasia (anggap p dan q sebagai bahan pembentuk N), bisa dihitung ulang dengan rumus aljabar sederhana.
C. Ketika p dan q sudah ketemu, seharusnya pesan asli dapat dibuka dengan perhitungan pangkat sederhana, sama seperti membuka gembok RSA pada umumnya.

Dua asumsi pertama terbukti benar dan asumsi ketiga meleset. Hal ini membuat soal kali ini menarik (dijelaskan di bagian 5).

3. Menyusun program (solevrr.py)

Karena perhitungan melibatkan angka-angka ratusan hingga ribuan digit, akan memakan waktu jika melakukan coba-coba manual. Maka dibuat program bernama solevrr.py yang bekerja bertahap dengan mengikuti alur di atas.

A. Tahap 1 —- Membaca Data Soal

Program akan memulai dengan membaca angka N, e, dan pesan terkunci (c) dari file soal, lalu menyusunnya dalam bentuk yang bisa diproses lebih lanjut oleh komputer.

B. Tahap 2 —- Menebak Private Key (Wiener Attack)

Program menjalankan proses pecahan berjenjang tadi pada e dan N. Setiap “tebakan” yang muncul dari proses ini langsung dicoba: apakah tebakan tersebut jika dipasangkan kembali dengan e menghasilkan hubungan yang konsisten dengan pola e x d ≈ -1 yang ditemukan di awal? Program mencoba ribuan kemungkinan secara otomatis sampai menemukan satu tebakan yang benar-benar cocok.

C. Tahap 3 —- Membongkar N Menjadi Dua Bilangan Prima

Ketika pola private key berhasil ditebak, program memakainya untuk menghitung ulang dua bilangan prima rahasia (p dan q) yang menjadi bahan dasar N. Proses ini dicek ulang dengan mengalikan kembali p x q, jika hasilnya sama persis dengan N berarti tebakan di tahap sebelumnya benar.

Hasilnya ternyata cocok. Ini adalah titik pertama yang membuktikan bahwa arah penyelesaian sudah tepat.

D. Tahap 4 —- Cara Buka Kunci Standar Tidak Bekerja

Di titik ini, langkah berikutnya harusnya sederhana: pakai private key untuk membuka pesan, sama seperti biasanya. Tapi hasilnya berupa angka acak yang tidak berarti, bukan tulisan yang bisa dibaca.

Setelah ditelusuri, ternyata masalahnya ada di cara soal ini menyusun ruang penyimpanan pesannya (semacam "loker" tempat pesan disimpan sebelum dikunci). Loker ini dianggap oleh soal sebagai satu ruang besar yang utuh, padahal pada kenyataannya, untuk bilangan prima yang dipakai loker itu ternyata terbagi menjadi beberapa ruang kecil yang terpisah. Rumus buka-kunci standar hanya berlaku kalau lokernya utuh, sehingga perlu penyesuaian.

E. Tahap 5 —- Menghitung Ulang Kunci Buka yang Sebenarnya

Program kemudian diperbaiki dulu untuk memetakan struktur "ruangan-ruangan kecil" tadi (faktorisasi polinomial). Dari peta itu, program bisa menghitung kunci pembuka yang benar-benar sesuai dengan struktur asli, bukan struktur yang diasumsikan sejak awal.

Dengan kunci yang sudah diperbaiki ini, pesan akhirnya bisa dibuka menjadi rangkaian angka yang, setelah diterjemahkan menjadi huruf, membentuk kalimat yang bisa dibaca tanda bahwa proses berhasil.

4. Hasil

Setelah melewati lima tahapan di atas, didapatkan pesan yang berisi :

COMPFEST{c0ngr4tzzz_h3ngk3rrrr_g3n3r4l1Zed_w13n3R_4ttacK}

Dari flag yang didapatkan juga seakan-akan menjadi konfirmasi dari pembuat soal bahwa soal "hello" memang menunjukkan teknik yang dipakai di atas merupakan teknik yang dituju.

5. Catatan

Format flag yang diminta oleh sistem sedikit berbeda dari hasil pembongkaran di atas (pada hasil pembongkaran memberikan pesan ("**COMPFEST{c0ngr4tzzz_h3ngk3rrrr_g3n3r4l1Zed_w13n3R_4ttacK}**"). Sedangkan setelah dilihat format flag di sistem, seharusnya ada tambahan angka "**18**" setelah kata "**COMPFEST**". Setelah di telusuri ke source code soal, ditemukan perbedaan ini berasal dari penulisan flag di soal, bukan dari kesalahan proses pembongkaran. Setelah dikonfirmasi, flag hasil pembongkaran tetap diterima oleh sistem. Maka dari itu, flag sebenarnya yaotu

COMPFEST18{c0ngr4tzzz_h3ngk3rrrr_g3n3r4l1Zed_w13n3R_4ttacK}

6. Ringkasan Alur

- Membaca source code —> ditemukan hubungan tak biasa antara public key dan private key.
- Mengenali pola sebagai varian Wiener Attack —> menggunakan pendekatan pecahan berjenjang untuk menebak private key.
- Menggunakan private key yang didapat untuk membongkar dua bilangan prima pembentuk N.
- Mencoba membuka pesan dengan cara standar —> gagal. Ditemukan struktur "ruangan" yang ternyata dibagi-bagi.
- Memetakan struktur asli, hitung ulang kunci pembuka yang cocok —> pesan berhasil dibuka.
- Mendapatkan flag, mencocokkan dengan sistem, melaporkan catatan kecil mengenai format penulisan.